

Warsaw, April 29, 2024

Decision

DKN.5131.29.2023

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended) in connection with Articles 7, 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Article 57(1)(a) and (h), Article 58(2)(d) and (i), Article 83(1) – (3), Article 83(4)(a) in connection with Article 24(1), Article 25(1), and Article 32(1) and (2), as well as Article 83(5)(a) in connection with Article 5(1)(f) and Article 5(2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the processing of personal data by Res-Gastro M. Gaweł Sp. k. based in Kolbuszowa (Kolbuszowa, ul. Obrońców Pokoju 85B), the President of the Personal Data Protection Office, stating that Res-Gastro M. Gaweł Sp. k. based in Kolbuszowa (Kolbuszowa, ul. Obrońców Pokoju 85B) violated the provisions of Article 24(1), Article 25(1), and Article 32(1) and (2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679", consisting of the failure by Res-Gastro M. Gaweł Sp. k. based in Kolbuszowa:

- a) to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of data processing using external data carriers, in order to protect the personal data stored there, including protection against accidental loss, destruction, or damage, as well as disclosure to unauthorized persons;
- b) to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing,

which resulted in a violation of Article 5(1)(f) (principle of integrity and confidentiality) and Article 5(2) of Regulation 2016/679 (principle of accountability):

1. imposes on Res-Gastro M. Gaweł Sp. k. based in Kolbuszowa (Kolbuszowa, ul. Obrońców Pokoju 85B) an administrative fine of 238,345 PLN (in words: two hundred thirty-eight thousand three hundred forty-five zlotys) for the violation of Article 5(1)(f), Article 5(2), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679;
2. orders Res-Gastro M. Gaweł Sp. k. based in Kolbuszowa (Kolbuszowa, ul. Obrońców Pokoju 85B) to bring its processing operations into compliance with the provisions of Regulation 2016/679 by implementing appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing, within 3 months from the date of delivery of this decision.

Justification

Res-Gastro M. Gaweł Sp. k. based in Kolbuszowa (Kolbuszowa, ul. Obrońców Pokoju 85B), hereinafter also referred to as the Administrator, is an entity whose primary business activity is focused on operating restaurants and other catering establishments (a total of eight restaurants). The Administrator, on July 26, 2023 (date of dispatch: July 21, 2023), reported to the President of the Personal Data Protection Office (hereinafter also referred to as the "President of UODO" or "supervisory authority") a personal data breach, which was registered under the reference number DKN.5130.9144.2023.

In the report of the personal data breach, the Administrator indicated that on July 19, 2023, he received a notification from an employee informing him about the loss of an external data carrier (a work USB drive) containing partially encrypted personal data of another employee of the administrator. In connection with the aforementioned report of the data breach, in a letter dated July 27, 2023, the President of the Personal Data Protection Office requested the Administrator to provide additional clarifications regarding:

- 1) specifying the detailed data or documents that were on the aforementioned data carrier (USB drive) and the personal data of the employee that were not encrypted;
- 2) indicating whether the data carrier in question (USB drive) was company property or the employee's personal property;
- 3) providing information regarding the existing procedure for the use of external data carriers, specifying the security measures for these carriers (including the data contained on them) and the method of monitoring compliance with the aforementioned procedure by employees;
- 4) providing information on whether the Administrator conducted a risk assessment regarding the processing of personal data using external data carriers and submitting the results of the aforementioned assessment.

In response to the inquiry, in a letter dated...

August 11, 2023 (date of receipt: August 21, 2023, date of dispatch: August 16, 2023)

The Administrator indicated that the lost external data storage device (USB drive) contained unencrypted files with personal data of an employee, including first name and surname, residential address, nationality, gender, date of birth, PESEL number, series and number of the passport, phone number, email address, photograph (image), and salary information. Additionally, the aforementioned data storage device also contained encrypted files with financial data. The Administrator emphasized that the cited (...) "the lost data storage device in the form of a USB drive was for business purposes and was the property of Res-Gastro M. Gawel Sp. k.". Furthermore, it was indicated that the procedure for handling and securing electronic data storage devices in the organization is regulated by the applicable "Instruction (...)". At the same time, the Administrator, in response to the question regarding the method of monitoring compliance with the procedure related to the use of external data storage devices by employees, submitted to the supervisory authority: - "Instruction (...)" (the last update took place in (...) April 2022, according to the attached scan of the aforementioned document), - confirmation of monitoring procedures related to GDPR for the years 2022 and 2023 in the form of a document titled "List (...)" from the years 2022 and 2023, - register (...), - anonymized email from June 16, 2023 (informing about the rules for securing data storage devices), - risk analysis.

In connection with the reported breach of personal data protection and the explanations provided by the Administrator in the letter dated August 11, 2023, as well as the submitted documents, the President of UODO on September 26, 2023, initiated ex officio administrative proceedings regarding the possibility of a breach by Res-Gastro M. Gawel Sp. k. based in Kolbuszowa, as the data controller, of the obligations arising from Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), Article 32(1) and 2 of Regulation 2016/679, in connection with the breach of personal data protection of the person whose data was on the lost external data storage device (USB drive) (reference number DKN.5131.29.2023). At the same time, due to the need to obtain additional and necessary information to conduct a proper analysis of the subject proceedings, the President of UODO on September 26, 2023, requested the Administrator to provide the following explanations:

- 1) whether the Administrator, in addition to the Instruction (...), developed and implemented a separate procedure defining the principles of encrypting files/data (including instructions on how to properly encrypt a file/data or which program to use for this task), as the aforementioned document generally indicated guidelines regarding encryption, cited "(...) in the case of taking data storage devices containing data outside the organization, they must be encrypted beforehand";
- 2) whether the employee who lost the subject storage device (USB drive) had the Administrator's consent to copy personal data to this device. According to point (...) of the Instruction (...), obtaining the Administrator's consent is required for the aforementioned activity;

3) how the Administrator verifies and monitors compliance by employees with the provisions of the Instruction (...) regarding point (...) cited “(...)” and point (...) cited “(...)”.

The Administrator, in a letter dated October 11, 2023 (date of receipt: October 17, 2023, date of dispatch: October 12, 2023), responded to the issues raised in the letter dated September 26, 2023 (reference number DKN.5131.29.2023) and indicated that in addition to the applicable “Instruction (...)”, a separate instruction regarding the method of encrypting files on data storage devices had been introduced. The subject instruction was prepared in the form of an instructional video, to which the website address (URL) was indicated in this letter. Furthermore, the Administrator noted that cited “Each employee to whom a USB drive was entrusted also received consent to copy data to the USB drive, including the employee who committed the breach, who received such consent on February 4, 2020. The content of the consent includes information about the aforementioned link to the instructional video on encrypting USB drives. Additionally, the Administrator informed all employees who received business USB drives for use in emails dated June 14, 2018, and July 27, 2018, about the aforementioned encryption instruction. The Administrator regularly reminded employees of the obligation to encrypt USB drives and the encryption instruction during training and meetings.” Attached to the aforementioned letter from the Administrator dated October 11, 2023, were: - a copy of the authorization for processing personal data for the employee who lost the subject data storage device (USB drive), - a copy of the consent to copy data to the USB drive for the aforementioned employee. After initiating ex officio administrative proceedings on September 26, 2023, the supervisory authority, wishing to clarify the factual state in this matter, in letters dated October 23, 2023, and December 1, 2023, requested the Administrator to:

1) provide detailed explanations and appropriate evidence regarding the position taken by the Administrator in the letter dated October 11, 2023, that the subject data storage device (i.e., USB drive) was cited “(...) this employee lost it not in a public place, but on the premises of the workplace in an area accessible only to employees of the Administrator.”

2) Provide information regarding the conduct of a new risk analysis for the processing of personal data operations after the occurrence of the subject breach of personal data protection.

The Administrator, in a letter dated November 7, 2023, explained that cited “The Administrator's position that the subject USB drive was lost not in a public place, but on the premises of the workplace, in an area accessible only to employees of the Administrator, is based on the explanations of the employee who...

committed a violation. This employee provided detailed oral explanations of the situation on July 20, 2023, which were subsequently confirmed in writing on November 3, 2023.” The Administrator attached a copy of the employee's explanations from November 3, 2023, to the letter sent to the supervisory authority on November 7, 2023, citing “(...) outlining the course and circumstances of the loss of the USB drive.” Furthermore, in a letter dated December 18, 2023, the Administrator submitted an updated risk analysis conducted on August 1, 2023, to the President of the UODO and indicated that “(...) USB drives are no longer used in the internal operations of the administrator.”

In this factual context, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

According to Article 34 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the Act of May 10, 2018, the President of the UODO is the competent authority for data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority monitors and enforces the application of this regulation within its territory and conducts proceedings regarding violations of this regulation, including based on information received from another supervisory authority or another public body.

Article 5 of Regulation 2016/679 establishes the principles regarding the processing of personal data that must be respected by all controllers, i.e., entities that determine the purposes and means of processing personal data either alone or jointly with others. According to Article 5(1)(f) of Regulation

2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (“confidentiality and integrity”). Furthermore, according to Article 5(2) of Regulation 2016/679, the controller is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance (“accountability”). The specification of the principle of confidentiality referred to in Article 5(1)(f) of Regulation 2016/679 is provided by further provisions of this regulation, including Article 24(1) of Regulation 2016/679, which states that taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with Regulation 2016/679 and to be able to demonstrate this. These measures are reviewed and updated as necessary. As indicated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity are factors that the controller is obliged to consider in the process of building a data protection system, particularly in light of the other obligations specified in Article 25(1), Article 32(1), and Article 32(2) of Regulation 2016/679.

The indicated provisions specify the principle of confidentiality defined in Article 5(1)(f) of Regulation 2016/679, and compliance with this principle is necessary for the proper implementation of the accountability principle resulting from Article 5(2) of Regulation 2016/679. According to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity arising from processing, the controller—both when determining the means of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide necessary safeguards for processing to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller is obliged to implement technical and organizational measures that correspond to the risk of infringement of the rights and freedoms of natural persons of varying likelihood and severity. The provision specifies that when deciding on technical and organizational measures, one must take into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity. From the cited provision, it follows that determining appropriate technical and organizational measures is a two-step process. First, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures.

ensure the security of processing. According to Article 32(2) of Regulation 2016/679, the controller, when assessing whether the level of security is appropriate, takes into account, in particular, the risks associated with processing, in particular those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed.

Considering in particular the scope of personal data processed by the Controller, contained in the file located on the lost external data storage device (i.e., USB drive), in order to properly fulfill the

obligations imposed by the aforementioned provisions of Regulation 2016/679, the Controller was obliged to take actions ensuring an adequate level of data protection by implementing appropriate technical and organizational measures to ensure the security of the processed personal data. The nature and type of these actions should result from the conducted risk analysis, in which vulnerabilities related to the utilized resources and the threats arising from them should be identified, and then appropriate security measures should be determined. An incorrect assessment of the level of risk prevents the application of appropriate security measures for a given resource and increases the likelihood of its occurrence. The result of the above was the loss of control over the personal data of the individual whose data was on the lost external data storage device.

It should be noted that Regulation 2016/679 introduced an approach in which risk management forms the foundation of actions related to the protection of personal data. Risk management is a continuous process that requires the data controller not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. Therefore, it becomes necessary to demonstrate to the supervisory authority that the implemented solutions aimed at ensuring the security of personal data are adequate to the level of risk, as well as take into account the nature of the given organization and the mechanisms used for processing personal data. The Controller is thus required to conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk.

The consequence of such an approach is the necessity of independently selecting safeguards based on a threat analysis. Specific security measures and procedures are not indicated to the Controllers. Conducting a detailed analysis of the ongoing data processing processes and assessing the risk is the obligation of the Controller, who should then, based on such analysis, apply such measures and procedures that will be adequate to the estimated risk.

Consequently, a properly conducted risk assessment provides the controller with the ability to determine and implement technical and organizational measures that will eliminate or at least significantly reduce the established level of risk of materialization of identified threats to the processed personal data. The risk assessment conducted by the controller should be documented and justified by the factual state existing at the time of its conduct. The main factors constituting a proper assessment that should be taken into account during the analysis include the characteristics of the processing processes, assets, vulnerabilities, threats, and current safeguards.

It should be remembered that significant factors in assessing risk also include the scope and nature of the personal data processed by the controller, as these will determine any potential negative consequences for the individual occurring at the moment of a breach of the protection of their personal data. The risk analysis presented by the Controller in the form of a document titled "Register (...)" (date of execution: April 15, 2022) includes processing activities related to the use of external data storage devices. Analyzing the submitted document, it should be stated that among the listed threats, the Controller did not indicate the possibility of an event involving the loss of an external data storage device (i.e., USB drive) by the employee to whom it was entrusted.

The provided analysis indicated a threat related to burglary and theft; however, it should be noted that these are threats associated with the active actions of third parties aimed at removing items from the owner's control for the purpose of appropriation, whereas, according to the semantic meaning of the word "lose," it means leaving something somewhere unwittingly or through negligence. Therefore, it cannot be assumed that burglary and theft of a data storage device are synonymous with its loss. In summary, it should be accepted that the Controller inadequately conducted the aforementioned analysis, thus failing to take into account all possible risks associated with the use of external data storage devices by employees. The Controller therefore neglected to conduct a risk analysis for the situation that led to the reported breach of personal data protection submitted to the President of the UODO, which should be considered non-compliant with the provisions of Regulation 2016/679 cited above. Meanwhile, as indicated by the WSA in Warsaw in the judgment of May 13, 2021, case file II

SA/Wa 2129/20, "The data controller should therefore conduct a risk analysis and assess what risks are associated with..."

"dealing with threats."

It is also worth noting that the Administrator, for the identified threat of burglary and theft of equipment (including external data storage devices), in order to eliminate or at least limit it, has provided technical safeguards in the form of the quote: "...". It should be emphasized that the proper and effective application of this security measure would have secured the data processed using external data storage devices against unauthorized access even in the event of the loss of such a device. However, the Administrator, contrary to the conducted risk analysis, did not implement the adopted technical measure, i.e., did not implement cryptographic solutions for the protection of personal data processed using company external data storage devices at the disposal of its employees.

It should also be mentioned here that the Administrator had implemented a procedure related to the use of external data storage devices. The "Instruction (...)", the last update of which was made on April 15, 2022 (according to the document submitted by the Administrator), refers in point (...) to the method, place, and duration of storage of electronic information storage devices containing personal data, including external data storage devices (USB drives). In the aforementioned chapter, among other things, the issue of forms of securing the aforementioned data storage devices has been regulated. According to the introduced rules at Res-Gastro M. Gawel Sp. k. based in Kolbuszowa, the quote: "... (...). Furthermore, it is worth noting points (...) and (...) of the document in question, according to which the quote: "...", as well as "...".

Despite the above provisions of the "Instruction (...)", the Administrator allowed the possibility of taking external data storage devices outside its premises, but with the application of appropriate forms of security, the quote: "In the case of taking data-containing devices outside the organization, they must be encrypted in advance."

In the explanations submitted, the Administrator informed the supervisory authority that the quote: "in addition to the Instruction (...), prepared a separate instruction explaining how to encrypt files on a USB drive and what program to use for this purpose" and provided a link where one can familiarize themselves with the aforementioned instruction (prepared in the form of a tutorial video). The instructional video explains how to encrypt the files with data presented in the material using the program (...). Considering the form used by the Administrator (tutorial video) to convey key guidelines to employees regarding the proper securing of external data storage devices (USB drives), it is not possible to make a reliable assessment of its effectiveness and the real knowledge and skills acquired by employees in this regard (lack of subsequent verification activities to ensure that the Administrator's employees are familiar with the material).

In the established factual state, it should therefore be assumed that the Administrator shifted the responsibility for implementing security measures in the form of encrypting external data storage devices (USB drives) onto its employees, and did not take any actions in this regard aimed at applying appropriate technical measures to ensure the protection of this data, despite the fact that in the conducted risk analysis for the threat of burglary and theft of equipment, which should be reiterated, it provided for technical security in the form of the quote: "...". and contrary to its obligations arising from Regulation 2016/679. It cannot be considered that the introduction of an obligation to encrypt external data storage devices (USB drives) in the internal document of the Administrator and providing employees using these devices with a link to a video with instructions for their encryption constitutes proper fulfillment of these obligations, since ultimately the obligation to apply this specific technical security measure rested with the employee. In this context, it is worth pointing out the judgment of the Provincial Administrative Court in Warsaw of February 15, 2022, case file II SA/Wa 3309/21, in which it was emphasized that "An employee cannot replace the data administrator in the performance of their tasks arising from these regulations. Furthermore, an employee may not possess the appropriate knowledge in this regard, ignore the necessity of securing the device (as was the case here) [...] or implement security that is inadequate to the scope and nature of the data and the risks occurring in this data processing process. The conclusions of the authority are accurate, as such an organized process

of determining and implementing security measures for processed personal data results in depriving the data administrator of basic information necessary to properly conduct a risk analysis and, based on that, build an effective data protection system necessary for continuously ensuring the confidentiality of data, in accordance with the requirement arising in particular from Article 32(1)(b) of Regulation 2016/679. They will not have knowledge of what security measures exist in their organization, to what extent and in the case of what threats they will be effective, and they are also deprived of information and the ability to respond to the implementation of security that is inadequate to the threats.”

At this point, it is also necessary to refer to the Administrator's position regarding the potential location of the loss of the data storage device (USB drive). According to the information provided in letters dated August 11 and November 7, 2023, the quote: “the USB drive in question was lost not in a public place, but on the premises of the workplace, in a part to which only the Administrator's employees have access.” The above statement by the Administrator results from explanations provided by the employee who lost the external data storage device.

(pendrive). According to the explanations attached to the Administrator's letter dated November 7, 2023, it follows that the subject data storage device has not been found, quote: “When leaving for home, I asked the Manager (...) and the Manager (...) to check everything again and search those rooms thoroughly while cleaning the restaurant, but they also found nothing. After unsuccessful searches, on July 19, 2023, I reported the loss of the pendrive to the coordinator.” In connection with the above, it cannot be excluded not only the possibility of unauthorized persons accessing the data on the lost external data storage device (pendrive) but also that it was taken outside the Administrator's organization. It should also be emphasized that even if it were accepted that the aforementioned device was indeed lost on the premises of the workplace, this does not change the assessment of the event in question. It contained personal data of the Administrator's employee that was not secured against access by unauthorized persons (e.g., by using encryption mechanisms), and thus the risk of a breach of confidentiality of this data existed (and still exists) regardless of who (the Administrator's employee or an outsider) found or will find this device. It should be emphasized that not every employee of the Administrator is authorized to process personal data of other employees.

It should therefore be emphasized that the assessment of the probability of a given event occurring should not be based solely on the frequency of occurrences of events in a given organization, as the fact that a particular event has not occurred in the past does not mean that it cannot occur in the future. In this context, it should be noted that the Provincial Administrative Court in Warsaw, in its judgment of August 26, 2020, case file II SA/Wa 2826/19, stated that “(...) technical and organizational activities are the responsibility of the personal data administrator, but they cannot be selected in a completely free and voluntary manner, without considering the degree of risk and the nature of the protected personal data.”

In the case at hand – due to the failure to consider the risk associated with the loss of such a device in the risk analysis conducted prior to the occurrence of the breach of personal data protection for data processing operations using external data storage devices (pendrives) – the Administrator did not determine (and consequently did not apply) appropriate security measures to reduce the risk of this threat materializing to an acceptable level. It should be emphasized that conducting a proper risk analysis before allowing employees to use external data storage devices (pendrives) and subsequently monitoring the adopted security procedures would have minimized the risk of the occurrence of the breach of personal data protection in question and would have fulfilled the accountability obligation imposed on the Administrator under Article 5(2) of Regulation 2016/679.

It should also be noted that new risks or threats may materialize or be revealed independently, in a manner completely independent of the administrator, and this is a fact that should also be taken into account both when constructing the personal data protection system and during its implementation. In this regard, it is the Administrator's obligation to conduct periodic risk analyses to verify whether new threats to the processed personal data have emerged, including when using external data storage devices (pendrives), and whether the security measures currently in place are appropriate, i.e., whether they allow for their elimination or at least reduction to an acceptable level of risk.

The Administrator conducted a new risk analysis after the occurrence of the breach of personal data protection, i.e., on August 1, 2023, in which it took into account the threats to the processing of personal data following the loss of the external data storage device used for processing. Furthermore, according to the declaration provided in the letter dated December 18, 2023, the Administrator has ceased using the aforementioned data storage devices in its operations. Risk management (conducting a risk analysis and implementing appropriate safeguards based on it) is one of the fundamental elements of the personal data protection system and is a continuous process. Therefore, there should be periodic verification of both the adequacy and effectiveness of the applied safeguards, in accordance with the requirement set out in Article 32(1)(d) of Regulation 2016/679. The data administrator should therefore regularly test, measure, and evaluate the effectiveness of technical and organizational measures to ensure the security of processing.

It should be emphasized that the indicated testing, measuring, and evaluating, in order to fulfill the requirement arising from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, which means consciously planning and organizing, as well as documenting (in connection with the accountability principle mentioned in Article 5(2) of Regulation 2016/679) such activities within specified time intervals, regardless of changes in the organization and the course of data processing processes. As indicated by the Provincial Administrative Court in Warsaw in its judgment of June 6, 2023, case file II SA/Wa 1939/22, "(...) the obligation to regularly test technical and organizational measures to secure the processing of personal data, in order to ensure a level of security corresponding to that risk, in the sense of Article 32(1) introductory sentence of the GDPR, directly arises from the wording of point (d) of the indicated Article 32(1), while the obligation to document actions in this regard is established by the principle of accountability (Article 5(2) of the GDPR)." Similarly

the necessary regular testing, measurement, and evaluation of the effectiveness of technical and organizational measures to ensure the security of personal data processing, has failed to fulfill its obligations under Article 32(1)(d) of the GDPR.

The Voivodeship Administrative Court in Warsaw expressed its opinion in a judgment dated June 21, 2023, case reference II SA/Wa 150/23, stating that "It should be emphasized that regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of processing is a fundamental obligation of every data controller and processor arising from Article 32(1)(d) of the GDPR. The controller is therefore obliged to verify both the selection and the level of effectiveness of the technical measures used at every stage of processing. The complexity of this verification should be assessed in light of its adequacy to risks and proportionality in relation to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of processing."

It should therefore be noted that the described testing, measuring, and evaluating must concern not only the implemented technical measures but also those of an organizational nature, including, among others, procedures defining the principles of personal data processing, including the use of external data carriers (USB drives). The actions in this regard primarily involve reviewing them for effectiveness, which includes not only checking whether a specific procedure is followed by employees but also examining whether the implemented security measures contribute in a real way to reducing risk. However, in the factual state in question, it should be concluded that the Administrator did not duly fulfill the obligation imposed on it regarding regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processing.

Analyzing the document submitted in the letter dated August 11, 2023, titled "List (...)" for the year 2022, prepared on March 7, 2022, it should be noted that the Administrator did not conduct a review of compliance with the provisions regarding the use of external data carriers (i.e., USB drives) by employees, as specified in the "Instruction (...)". The only areas checked concerning external data carriers were those described in point (...) cited as "...", point (...) cited as "...", and point (...) cited as "...". In the "List (...)" for the year 2023, prepared on June 16, 2023, identical control points

corresponding to points no. (...) and (...) are included.

A significant change that was not included in the "List (...)" dated March 7, 2022, but appeared in the document dated June 16, 2023, is the statement that cited "...", which received a negative response, and the information cited "...". It is worth noting here that according to the records of point (...) of the "Instruction (...) cited "...". The aforementioned facts are therefore in opposition to the declaration of the Administrator indicated in the letter dated October 11, 2023, from which it can be inferred that the removal of data carriers from the workplace did not occur, as cited, "so far there has been no case where an employee submitted a request for the possibility of taking a USB drive outside the workplace, and the administrator did not grant such consent."

Furthermore, in the same letter, the Administrator informed that cited, "a general prohibition on copying to data carriers any information containing personal or confidential data concerning the administrator is in effect, as well as a general prohibition on removing data carriers containing personal or confidential data concerning the administrator outside the workplace." In light of the above, it should be concluded that the procedure related to the use of external data carriers (USB drives) indicated in the "Instruction (...)" was in no way enforced by the Administrator, as the violation of personal data protection consisted of the loss by an employee of an external data carrier (USB drive) containing files with unencrypted personal data of the employee and encrypted financial data. The above also indicates the ineffectiveness of this organizational security measure, as the prohibition on removing external data carriers (USB drives) outside the Administrator's organization without its consent was practically violated by employees. This also determines the necessity to accept that the monitoring of compliance with the procedures regarding the use of external data carriers (USB drives) by employees carried out in this manner did not fulfill its function, and consequently, it cannot be considered as fulfilling the obligation specified in Article 32(1)(d) of Regulation 2016/679.

It is also worth noting that individuals entrusted with external data carriers (USB drives) had the appropriate authorization to process personal data and copy data to that specific carrier. Therefore, not all employees of the Administrator had access to the personal data of employees. In light of the above, the group of individuals who should be subject to special monitoring of compliance with the regulations, as should be assumed, was not large, which certainly facilitated the Administrator in fulfilling the requirement imposed by Article 32(1)(d) of Regulation 2016/679. The Administrator itself granted the relevant authorizations to employees regarding the processing of personal data and their copying, thus having knowledge of the specific individuals who should be subject to additional and broader supervision in the application of the adopted procedures related to the protection of personal data processed using external data carriers (USB drives).

In light of the findings made during this proceeding, it should be indicated that the Administrator, by not applying technical and organizational measures ensuring the security of processed data, resulted in a violation of personal data protection reported to the President of the UODO, and also failing to conduct the necessary regular testing, measurement, and evaluation of the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processing.

regular testing, measuring, and assessing the effectiveness of the applied security measures, violated Article 5(1)(f) of Regulation 2016/679, reflected in the obligations specified in Article 24(1), Article 25(1), Article 32(1), and Article 32(2). The consequence of violating Article 5(1)(f) of Regulation 2016/679 is a breach of the accountability principle expressed in Article 5(2) of Regulation 2016/679. As stated in the judgment of the Provincial Administrative Court in Warsaw dated February 10, 2021, case file II SA/Wa 2378/20, "The accountability principle is therefore based on the legal responsibility of the controller for properly fulfilling obligations and imposes on them the duty to demonstrate, both to the supervisory authority and to the data subject, evidence of compliance with all data processing principles." Similarly, the Provincial Administrative Court in Warsaw interprets the accountability principle in its judgment dated August 26, 2020, case file II SA/Wa 2826/19, "Considering the entirety of the norms of Regulation 2016/679, it should be emphasized that the controller has significant discretion regarding the security measures applied, while at the same time being responsible for violations of personal data protection regulations. The accountability principle directly implies that it is

the data controller who should demonstrate, and thus prove, compliance with the provisions specified in Article 5(1) of Regulation 2016/679.”

In light of the above irregularities, as well as the content of Article 58(2)(d) of Regulation 2016/679, the President of the Personal Data Protection Office (UODO) ordered the Controller to adjust the processing operations to the provisions of Regulation 2016/679 by implementing appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of the technical and organizational measures intended to ensure the security of processing.

When assessing the circumstances of the personal data protection violation in question, it should be emphasized that when applying the provisions of Regulation 2016/679, it is important to keep in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the event of any doubts, for example, regarding the fulfillment of obligations by controllers – not only in situations where there has been a breach of personal data protection but also when developing technical and organizational security measures to prevent such breaches – these values should be taken into account first and foremost.

Taking into consideration the above findings and the established violations of the provisions of Regulation 2016/679, the President of UODO, exercising the authority granted to him under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this regulation, an administrative fine pursuant to Article 83(4)(a) and (5)(a) of Regulation 2016/679, having regard to the circumstances established in the proceedings, found that there were grounds for imposing an administrative fine on the Controller.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the controller and the processor referred to in Articles 8, 11, 25-39, and 42 and 43 are subject, according to paragraph 2, to an administrative fine of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject, according to paragraph 2, to an administrative fine of up to EUR 20,000,000, or in the case of an enterprise, up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. Article 83(3) of Regulation 2016/679 states that if the controller or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative fine shall not exceed the amount of the fine for the most serious violation.

In this case, the administrative fine imposed on the Controller was for violating Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for violating Article 5(1)(f) and Article 5(2) of Regulation 2016/679 – based on Article 83(5)(a) of this regulation. At the same time, the administrative fine in the amount of PLN 238,345 (in words: two hundred thirty-eight thousand three hundred forty-five) imposed on the Controller for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the fine for the most serious violation established in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative fine of up to EUR 20,000,000, or in the case of an enterprise, up to 4% of its total annual worldwide turnover from the previous year. rotating wheel.

In deciding to impose an administrative monetary penalty, the President of the UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present

matter and which adversely affect the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The violation of personal data protection regulations established in this case, which resulted in (and continues to result in) the possibility of unauthorized access to data located on an unsecured external data storage device (USB drive) by unauthorized person(s) (violation of the confidentiality principle), is of significant weight and serious nature, as it creates a high risk of negative consequences for the individual whose data is concerned. The violation by Res-Gastro M. Gawel Sp. k. based in Kolbuszowa of the obligation to implement security measures to protect the processed data from being disclosed to unauthorized persons not only entails a potential but also a real possibility of these data being used by third parties without the knowledge and against the will of the individual whose data is concerned, in violation of the provisions of Regulation 2016/679. Furthermore, as of the date of this decision, the lost external data storage device has not been found, so unauthorized person(s) may still have access to the personal data contained on that device. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. In turn, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that “Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which the individual whose data is concerned experiences as a result of a breach of this regulation, may in itself constitute ‘non-material damage’ within the meaning of this provision.”

It should also be emphasized that the violation of personal data protection regulations lasted for a long time, namely from April 15, 2022, when the Administrator improperly conducted a risk analysis, as demonstrated above, resulting in the failure to implement appropriate security measures to ensure the protection of personal data processed using external data storage devices (USB drives), until December 18, 2023, the date of the letter in which the Administrator informed about the cessation of the use of external data storage devices (USB drives) in its organization. In this case, the violation concerned the personal data of only one individual. Such a number of individuals affected by the violation should be considered small, which undoubtedly works in favor of the Administrator; however, this did not change the overall assessment, i.e., the recognition in the analyzed case of the criterion from Article 83(2)(a) of Regulation 2016/679 as aggravating.

2. The unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). The loss of control over the personal data of the individual whose data is on the lost external data storage device (USB drive) became possible due to the failure of Res-Gastro M. Gawel Sp. k. based in Kolbuszowa to implement appropriate security measures to ensure the protection of this data. In the opinion of the supervisory authority, this indicates the unintentional nature of the violation, resulting from the negligence of the Administrator, who improperly conducted a risk analysis for data processing operations using such storage devices, as it did not cover the threat that caused the violation of personal data protection. Furthermore, the Administrator had implemented a procedure regarding the method, location, and duration of storing electronic information storage devices containing personal data, as specified in the document titled “Instruction (...)”, but it was not effectively enforced, and the Administrator's employees did not comply with its provisions regulating the actions to be taken to ensure the security of data processed on external data storage devices (USB drives). The Administrator also created a separate instruction regarding file encryption in the form of a tutorial video, which explained how to encrypt files on a USB drive and which program to use for this purpose. After analyzing this instructional material available via the link provided by the Administrator, the authority found that it was not possible to make a reliable assessment of its effectiveness and the real knowledge and skills acquired by employees in this regard due to the lack of subsequent verification actions to ensure that the Administrator's employees were familiar with the material. In summary, it should therefore be accepted that the Administrator shifted the implementation of security measures in the form of encrypting external data storage devices (USB drives) onto its employees, while not taking any actions in this regard to apply appropriate technical measures to ensure the protection of data

contained on such devices. This raises doubts about the effectiveness of the monitoring actions conducted by the Administrator to ensure compliance by employees with the implemented procedures and the conducting of training for employees in the field of personal data protection.

3. The categories of personal data concerned.

breach (Article 83(2)(g) of Regulation 2016/679). The personal data contained on the lost external data storage device (USB drive), namely first name and surname, residential address, nationality, gender, date of birth, place of birth, PESEL number, series and number of the passport, phone number, email address, image (photo), and salary information do not include data subject to special protection under Article 9(1) and Article 10 of Regulation 2016/679. The PESEL identification number, which is an eleven-digit numerical symbol uniquely identifying a natural person, containing, among other things, the date of birth and also subject to exceptional protection as a national identification number under Article 87 of Regulation 2016/679, is data of a special nature and requires such special protection.

In this context, it is worth recalling the guidelines of the European Data Protection Board (EDPB) No. 04/2022 on calculating administrative fines under the GDPR adopted on May 24, 2023 (hereinafter referred to as "Guidelines 04/2022"), which state: "Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) [of Regulation 2016/679]), [Regulation 2016/679] explicitly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing fines. This applies at least to the types of data covered by Articles 9 and 10 [of Regulation 2016/679] and to data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are affected by the breach or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The amount of data concerning each individual whose data is affected also matters, increasing the scale of the breach of the right to privacy and the protection of personal data."

In deciding to impose an administrative fine, the President of the Personal Data Protection Office (UODO) took into account the following mitigating circumstances affecting the amount of the imposed administrative fine:

1. The degree of cooperation with the supervisory authority to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). Res-Gastro M. Gawel Sp. k. based in Kolbuszowa duly fulfilled its procedural obligations during the administrative proceedings that concluded with the issuance of this decision. It is also worth noting that the data subject was notified of the breach in a manner compliant with the requirements of Article 34 of Regulation 2016/679. The Administrator also took specific actions that resulted in employees ceasing to use external data storage devices (USB drives), thereby eliminating the possibility of a similar breach of personal data protection occurring in the future. Furthermore, the Administrator conducted a re-assessment of the risk following the occurrence of the data breach on August 1, 2023, in which it considered the threats to the processing of personal data as a result of the loss of the external data storage device used for processing.

2. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). On July 21, 2023, the Administrator sent a registered letter to the data subject providing proper notification of the data breach along with instructions on how to secure their personal data against further misuse and purchased a BIK report for the aforementioned individual containing a detailed credit history of that entity, in accordance with the Administrator's declaration expressed in the letter dated October 11, 2023, citing: "(...) Gastro M. Gawel Sp. k. purchased, for the person whose data is concerned, [...] a BIK report, as evidenced by the confirmation of sending the application by mail on August 10, 2023, and the confirmation of the transfer for the BIK report."

Other circumstances mentioned in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified breach in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative fine.

1. The degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The President of the UODO found that Res-Gastro M. Gawel Sp. k. based in Kolbuszowa violated the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the breach of personal data protection. It is evident that in the context of the nature, purpose, and scope of the processing of personal data, the Administrator did not "do everything that could have been expected of him"; thus, he did not fulfill the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679. However, in this case, this circumstance constitutes the essence of the breach itself; it is not merely a factor influencing – either mitigating or aggravating – its assessment. For this reason, the lack of appropriate technical and organizational measures, of which referring to Article 25 and Article 32 of Regulation 2016/679, cannot be considered by the President of the UODO in this case as a circumstance that could additionally influence a stricter assessment of the violation and the amount of the administrative fine imposed on the Administrator.
2. Any relevant previous violations by the administrator (Article 83(2)(e) of Regulation 2016/679). The President of the UODO found no previous violations of data protection regulations on the part of the Company, which means there are no grounds to treat this circumstance as aggravating. It is the duty of every administrator to comply with the law, and therefore the absence of previous violations cannot also be considered a mitigating circumstance when imposing sanctions.
3. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of the UODO identified the violation as a result of a report of a personal data breach made by Res-Gastro M. Gawel Sp. k. based in Kolbuszowa. By making this report, the Administrator fulfilled its legal obligation; therefore, there are no grounds to consider this circumstance as mitigating. According to the Guidelines on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 (Wp. 253), "The supervisory authority may become aware of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notification by the data controller. According to the regulation, the controller is obliged to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor." Similarly, the EDPB in Guidelines 04/2022 indicates that "when the controller is subject to specific obligations regarding the reporting of breaches (e.g., the obligation to report a personal data breach as specified in Article 33 of the GDPR), the fact of making a report should be considered a neutral circumstance."
4. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the administrator in the case under consideration, which means the administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating effect on the assessment of the identified violation.
5. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). Res-Gastro M. Gawel Sp. k. based in Kolbuszowa does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for controllers and processors according to the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

6. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of the UODO found that the administrator did not obtain any financial benefits or avoid such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the administrator. The existence of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. However, the failure of the administrator to achieve such benefits, as a natural state independent of the violation and its consequences, is a circumstance that inherently cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits “obtained” – that have occurred on the part of the entity committing the violation.

The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative fine, which should be included in the consideration of the premise from Article 83(2)(k) of Regulation 2016/679.

In the opinion of the President of the UODO, the administrative fine imposed fulfills, in the established circumstances of this case, the functions mentioned in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportionate, and deterrent in this individual case. According to the President of the UODO, the administrative fine imposed on Res-Gastro M. Gawel Sp. k. based in Kolbuszowa will be effective, as it will lead to a state in which Res-Gastro M. Gawel Sp. k. based in Kolbuszowa will implement such technical and organizational measures that will ensure that the processed data have a level of security corresponding to the risk of violation of the rights or freedoms of the data subjects and the severity of the threats associated with the processing of such personal data. The effectiveness of the administrative fine...

with the criteria set out in Article 83 of Regulation 2016/679) is indeed medium.

3. The President of the UODO also took into account the mitigating factors, including the fact that Res-Gastro M. Gawel Sp. k. has not previously been subject to any administrative fines for violations of data protection regulations, which may indicate a lack of prior misconduct.

4. Furthermore, the President of the UODO considered the corrective actions taken by the Administrator after the violation was identified, which may contribute to reducing the severity of the penalty.

5. In light of the above considerations, the President of the UODO determined that the administrative fine imposed is appropriate and necessary to ensure compliance with the provisions of Regulation 2016/679 in the future.

6. The President of the UODO emphasizes that the purpose of the fine is not only punitive but also preventive, aiming to encourage the Administrator to adhere to data protection regulations and to protect the rights of individuals.

7. In conclusion, the President of the UODO reiterates that the administrative fine of 238,345 PLN (in words: two hundred thirty-eight thousand three hundred forty-five) is justified and proportionate to the circumstances of the case, the severity of the violations, and the financial situation of the Administrator.

8. The decision may be appealed in accordance with applicable law, and the Administrator has the right to seek judicial review of the decision before the competent administrative court.

9. This decision is final and binding, and the Administrator is required to comply with the imposed fine within the specified timeframe.

10. The President of the UODO reserves the right to monitor compliance with this decision and to take further action if necessary to ensure adherence to data protection regulations.
of the administrative fine is appropriate and justified in light of the circumstances of the case.

7. The President of UODO concluded that the final amount of the administrative fine, set at 54,600.00 EUR (equivalent to 238,345 PLN), is not only compliant with the legal maximum stipulated in Article 83(3) of Regulation 2016/679 but also adheres to the principle of proportionality. This amount effectively serves the punitive and deterrent purposes of the sanction while remaining within reasonable limits, considering the specific circumstances of the infringement and the economic capacity of the Company.

8. In summary, the President of UODO has taken into account all relevant factors, including the nature and gravity of the infringement, the degree of cooperation with the supervisory authority, and the measures taken to mitigate the damage caused. The final decision reflects a balanced approach, ensuring that the penalty is both effective and fair, thereby fulfilling the objectives of the GDPR.

9. The Company has the right to appeal this decision in accordance with applicable legal provisions. The appeal should be lodged within the statutory time limit, and the Company will be informed of the procedures to follow in this regard.

10. This decision is issued in accordance with the powers vested in the President of UODO under the applicable laws and regulations, and it is binding upon the Company. The Company is required to comply with the terms of this decision and to take necessary actions to prevent future infringements.

11. The President of UODO reserves the right to monitor compliance with this decision and to take further actions as necessary to ensure adherence to data protection regulations.

12. This decision is effective immediately upon delivery to the Company.

Date: [Insert Date]

President of UODO: [Insert Name]

The imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which any further increase in the penalty amount will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the penalty amount could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

Pursuant to Article 103 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), the equivalent amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

In light of the above, the President of the Personal Data Protection Office, based on Article 83(4)(a) and Article 83(5)(a) in conjunction with Article 83(3) of Regulation 2016/679 and in conjunction with Article 103 of the Act of May 10, 2018 on the Protection of Personal Data, for the violation described in the operative part of this decision, imposed an administrative monetary penalty on Res-Gastro M. Gawel Sp. k. based in Kolbuszowa – applying the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – in the amount of 238,345 PLN (which is equivalent to 54,600 EUR).

The purpose of the imposed administrative monetary penalty is to ensure that Res-Gastro M. Gawel Sp. k. based in Kolbuszowa complies with the provisions of Regulation 2016/679 in the future, and consequently to conduct data processing processes in accordance with applicable legal regulations.

In this factual and legal state, the President of the Personal Data Protection Office decided as stated in the operative part.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-04-29

Information entered by:

Wioletta Golańska

2024-05-15 14:25:26

Last modified by:

Edyta Madziar

2024-05-17 11:00:27